

Kaitlin Hoffmann

Office Hours:

SH 243 Monday 1:15 - 3:15 PM. Tuesday 2:45 - 4:45 PM.

Email: hoffmank4@newpaltz.edu

INCIDENT RESPONSE AND MANAGEMENT

NETWORK SECURITY

OBJECTIVES

- ▶ Introduction
- ▶ NIST 800-61 Framework
- ▶ Tools and Technologies in IR and IM
- ▶ Best Practices



WHAT IS INCIDENT RESPONSE AND MANAGEMENT

- ▶ Incident Response and Management is a structured approach to handling security incidents to minimize damage and recovery time.
- ▶ Essential for protecting assets, maintaining trust, and preventing further attacks.
- ▶ Goals are to quickly detect, contain, and recover from incidents to prevent future occurrences.

TYPES OF SECURITY INCIDENTS

- ▶ **Malware Attacks:** Viruses, ransomware, spyware that damage systems or steal data.
- ▶ **Phishing and Social Engineering:** Tactics to deceive and gain unauthorized access.
- ▶ **Network Intrusions:** Unauthorized access leading to data breaches or service disruptions.
- ▶ **Insider Threats:** Malicious actions by trusted individuals with access.
- ▶ **Denial of Service (DoS):** Overloading systems to disrupt legitimate access.

NIST 800-61 FRAMEWORK

- ▶ The NIST 800-61 framework is a comprehensive guide developed by the National Institute of Standards and Technology (NIST) to assist organizations in establishing and maintaining an effective incident response (IR) process.
- ▶ Widely recognized in cybersecurity for its structured approach to incident response, ensuring organizations can effectively manage, contain, and learn from security incidents.
- ▶ <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>

PHASES OF NIST 800-61

- ▶ The NIST 800-61 framework has six Phases:
 1. Preparation
 2. Identification
 3. Containment
 4. Eradication
 5. Recovery
 6. Lessons Learned

PHASE 1 – PREPARATION

- ▶ **Developing an Incident Response Plan (IRP):** Establish roles, responsibilities, and protocols for incident response.
- ▶ **Building a Dedicated IR Team:** Define roles like incident manager, IT support, communications lead, etc.
- ▶ **Setting Up Tools and Processes:** Implement SIEM, EDR, backup systems, and forensic tools for readiness.
- ▶ **Training and Awareness Programs:** Ensure employees are prepared to recognize incidents and follow response protocols.

PHASE 1 – PREPARATION EXAMPLE

- ▶ **Example:** A healthcare organization **anticipates** potential ransomware attacks, so they develop a comprehensive Incident Response Plan (IRP).
- ▶ They establish an IR team, implement SIEM systems for real-time monitoring, and conduct regular employee training on recognizing phishing attempts to reduce risks.
- ▶ Example IRP: <https://security.uconn.edu/incident-response-plan/>

PHASE 2 – IDENTIFICATION

- ▶ **Detection Mechanisms:** Monitoring systems for signs of unusual activity using logs, alerts, and anomaly detection.
- ▶ **Confirming the Incident:** Analyzing data to determine if the event is a security incident.
- ▶ **Incident Severity Assessment:** Classify incidents by type and impact level to prioritize response efforts.
- ▶ **Tools:**
 - SIEM (Security Information and Event Management): Centralized logging and real-time monitoring.
 - IDS/IPS (Intrusion Detection/Prevention Systems): Detect and block suspicious activities.

PHASE 2 – IDENTIFICATION EXAMPLE

- ▶ **Example:** A financial institution's SIEM system detects unusual login attempts from foreign IP addresses on a weekend, outside of normal working hours.
- ▶ Security analysts investigate these alerts, confirming that the activity is likely unauthorized access attempts, possibly an attempted brute-force attack.

PHASE 3 – CONTAINMENT

- ▶ **Short-Term Containment:** Immediate actions to isolate affected systems, such as disconnecting from the network.
- ▶ **Long-Term Containment:** Implement measures to ensure systems can be safely operated until they are fully remediated.
- ▶ **Preventing Further Spread:** Close vulnerabilities, disable compromised accounts, and enhance monitoring.
- ▶ **Key Actions:**
 - Disconnect infected systems
 - Implement network segmentation to restrict movement

PHASE 3 – CONTAINMENT EXAMPLE

- ▶ **Example:** A retail company discovers a malware infection on several workstations used for customer transactions.
- ▶ To contain the malware, the team disconnects affected systems from the network, preventing further spread, and blocks specific IP addresses associated with the attack.

PHASE 4 – ERADICATION

- ▶ **Root Cause Analysis:** Identify the underlying vulnerabilities or causes of the incident.
- ▶ **Removing Threats:** Eliminate malware, malicious files, unauthorized access points, or other threats.
- ▶ **Remediation:** Apply patches, adjust configurations, and strengthen controls to prevent recurrence.
- ▶ **Tools for Eradication:**
 - Antivirus/Antimalware: Scan and remove malicious files.
 - Configuration Management: Ensure settings are secure and consistent.

PHASE 4 – ERADICATION EXAMPLE

- ▶ **Example:** A tech company finds that the root cause of a breach was a vulnerability in outdated software.
- ▶ After identifying the malicious software, the team removes it from all infected machines, patches the vulnerable software across the network, and configures enhanced firewall rules to prevent future exploitation.

PHASE 5 – RECOVERY

- ▶ **Validating System Cleanliness:** Ensure that all threats have been eradicated and no malicious actors remain.
- ▶ **Restoration of Services:** Gradually bring systems back online to normal operational states.
- ▶ **Continuous Monitoring:** Monitor systems post-recovery to detect any signs of residual issues.
- ▶ **Backup and Recovery:** Restore from clean backups and ensure integrity of data.

PHASE 5 — RECOVERY EXAMPLE

- ▶ **Example:** After eradicating a ransomware infection, a government agency restores affected systems using clean backups.
- ▶ They gradually reconnect these systems to the network while closely monitoring for any signs of reinfection, validating that all data is secure before fully resuming normal operations.

PHASE 6 – LESSONS LEARNED

- ▶ **Incident Documentation:** Create a detailed report of the incident, response actions, and outcomes.
- ▶ **Post-Incident Analysis:** Identify what went well, challenges faced, and areas for improvement.
- ▶ **IR Plan Update:** Modify the incident response plan based on lessons learned to better handle future incidents.

PHASE 6 – LESSONS LEARNED EXAMPLE

- ▶ **Example:** Following a successful incident response to a data breach, a corporation holds a post-incident review.
- ▶ They identify that faster detection could have reduced data exposure and decide to enhance their monitoring tools. The IR team updates the IRP and provides additional training to prevent similar incidents.

KEY ROLES IN INCIDENT RESPONSE

- ▶ **Incident Response Manager:** Oversees the response and coordinates team efforts.
- ▶ **Security Analysts:** Analyze logs, identify threats, and assess the severity of incidents.
- ▶ **IT Support Staff:** Provide technical support, system isolation, and troubleshooting.
- ▶ **Communication Leads:**
 - **Internal:** Update team members and stakeholders.
 - **External:** Manage public statements if necessary.
- ▶ **Legal and Compliance Teams:** Ensure that responses meet legal and regulatory requirements.

TOOLS AND TECHNOLOGIES IN INCIDENT RESPONSE

- ▶ **SIEM (Security Information and Event Management):** Centralized log collection and threat analysis.
- ▶ **EDR (Endpoint Detection and Response):** Monitors endpoints for suspicious activities.
- ▶ **Forensic Tools:** Aid in evidence preservation, recovery, and analysis.
- ▶ **Backup and Recovery Solutions:** Ensure secure data storage and quick restoration.

INCIDENT RESPONSE BEST PRACTICES

- ▶ **Rapid Detection and Containment:** Critical to reducing damage.
- ▶ **Updating the Incident Response Plan (IRP):** Regular reviews and updates to adapt to new threats.
- ▶ **Tabletop Exercises:** Simulations to prepare and test the response plan.
- ▶ **Compliance:** Ensuring adherence to legal and regulatory standards, like GDPR and HIPAA.

IR AND IM – ASSIGNMENT 8

- ▶ Lab for VM (See PDF)
- ▶ TryHackMe Labs:
 - <https://tryhackme.com/r/room/preparation>
 - <https://tryhackme.com/r/room/identificationandscoping>